

**1)How would you identify and prioritize vulnerabilities after discovering multiple open ports during a port scan? Explain your approach.**

After discovering multiple open ports during a port scan, vulnerabilities should be identified and prioritized based on the service running on each port, its version, known vulnerabilities, severity, and potential impact.

**Approach:**

1. **Identify the services:** Determine which service is running on each open port, such as HTTP, SSH, FTP, or SMB.
2. **Determine service versions:** Use service/version detection to identify the exact software and version running on the port.
3. **Check for known vulnerabilities:** Compare the identified software versions against vulnerability databases such as CVE/NVD to find known security issues.
4. **Assess vulnerability severity:** Consider the CVSS score, exploitability, and potential impact. Critical and high-severity vulnerabilities should receive higher priority.
5. **Consider exposure:** Internet-facing services and services accessible to many users should generally receive greater attention than isolated internal services.
6. **Prioritize remediation:** Fix critical and high-risk vulnerabilities first, especially those that allow remote code execution, authentication bypass, privilege escalation, or unauthorized access.
7. **Verify the fixes:** After remediation, perform another scan or security assessment to confirm that the vulnerabilities have been resolved.

**Example:**

If a scan discovers FTP, SSH, and HTTP, I would identify their versions and check for known vulnerabilities. If the HTTP service has a critical remote-code-execution

vulnerability while SSH has only a low-risk configuration issue, the HTTP vulnerability would be prioritized first.

### **Conclusion:**

The main goal is to prioritize vulnerabilities based on severity, exploitability, exposure, and business impact, rather than simply fixing vulnerabilities in the order they were discovered.

**2)SYN scan and a TCP Connect scan produce different results on the same target. What factors could cause this difference, and how would you verify the findings?**

### **Answer**

A SYN scan and a TCP Connect scan may produce different results on the same target because they use different methods to establish TCP connections.

Factors that can cause differences:

1. Firewall filtering: A firewall may treat SYN packets differently from complete TCP connections and may block or filter one type of scan.
2. Intrusion Detection/Prevention Systems (IDS/IPS): Security systems may detect SYN scans and block or alter their responses.
3. Network filtering: Routers, firewalls, or access-control rules may allow or reject specific types of TCP traffic.
4. Service behavior: Some services may respond differently depending on whether a complete TCP connection is established.
5. Network conditions: Packet loss, latency, or unstable network connectivity can cause inconsistent scan results.
6. Rate limiting: The target may temporarily limit or block repeated connection attempts, affecting subsequent scans.

### **How to verify the findings:**

- Run both scans again under the same network conditions.
- Perform service/version detection to identify the service running on the port.
- Compare the results from multiple scans.
- Check firewall or IDS/IPS logs if authorized.
- Manually test the suspected open port using an appropriate client or service connection.
- Use packet-capture tools such as Wireshark to observe the TCP responses.

### **Example Nmap commands:**

`sudo nmap -sS <TARGET_IP>`

SYN scan.

`sudo nmap -sT <TARGET_IP>`

TCP Connect scan.

### **Conclusion:**

Differences between SYN and TCP Connect scans are often caused by firewalls, IDS/IPS, filtering, service behavior, or network conditions. Repeating the scans and examining the actual TCP responses helps verify which result is accurate.

**3)During a port scan, most ports appear as "filtered." What security mechanisms might be responsible, and what additional techniques would you use to gather more information?**

When most ports appear as “filtered” during a port scan, it generally means that Nmap cannot determine whether the ports are open or closed because network security devices are preventing or dropping the scan packets.

**Security mechanisms responsible**

1. Firewall: A network or host-based firewall may block incoming connection attempts.
2. IDS/IPS: Intrusion Detection or Prevention Systems may detect scanning activity and drop or block packets.
3. Access Control Lists (ACLs): Routers or switches may restrict traffic from unauthorized sources.
4. Packet filtering: Security devices may silently discard packets instead of sending a response.
5. Rate limiting: The target may limit repeated connection attempts from the scanning system.
6. Network segmentation: The scanner may not have direct access to the network containing the target services.

### **Additional techniques**

To gather more information, an authorized tester can:

- Try different TCP scan methods such as SYN (-sS) and TCP Connect (-sT).
- Use UDP scanning (-sU) to check for UDP services.
- Perform service/version detection (-sV) on ports that respond.
- Compare results from different network locations if authorized.
- Examine firewall/IDS logs when access is available.
- Use packet capture tools such as Wireshark to analyze whether packets are being dropped or rejected.
- Perform scans at controlled rates to determine whether rate limiting is affecting the results.

### **Example commands**

```
sudo nmap -sS <TARGET_IP>
```

```
sudo nmap -sT <TARGET_IP>
```

```
sudo nmap -sU <TARGET_IP>
```

## Conclusion

A large number of filtered ports usually indicates network filtering or security controls such as firewalls, ACLs, or IDS/IPS systems. Using different authorized scanning techniques and analyzing network responses can help determine why the ports are filtered and provide a more accurate assessment.

**4) Compare TCP, UDP, and stealth (SYN) port scanning techniques. In which scenarios would each be the most effective, and what are their advantages and limitations?**

| Scan Type                 | How it Works                                                                           | Most Effective When                                                             | Advantages                                                     | Limitations                                                                               |
|---------------------------|----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|----------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>TCP Connect Scan</b>   | Completes the full TCP three-way handshake                                             | When SYN scanning is unavailable or a reliable connection test is required      | Accurate and simple; does not require raw-packet privileges    | Easier for security systems to detect and creates a full connection                       |
| <b>UDP Scan</b>           | Sends UDP packets to identify UDP services                                             | When checking services such as DNS, DHCP, SNMP, or other UDP-based applications | Can discover UDP services that TCP scans cannot detect         | Usually slower; UDP often gives little or no response, making results harder to interpret |
| <b>SYN (Stealth) Scan</b> | Sends a SYN packet and analyzes the response without completing the full TCP handshake | General-purpose TCP port discovery, especially during security assessments      | Fast, efficient, and does not normally complete the connection | Can still be detected by firewalls/IDS/IPS; requires appropriate privileges               |

## TCP Connect Scan

A TCP Connect scan establishes a complete TCP connection with the target port.

**Example:**

```
sudo nmap -sT <TARGET_IP>
```

It is useful when the scanner cannot send raw packets or when a complete connection needs to be verified.

Limitation: More noticeable because the TCP connection is fully established.

## 2. UDP Scan

UDP scanning is used to identify services operating over UDP.

### Example:

```
sudo nmap -sU <TARGET_IP>
```

It is useful for discovering services such as DNS, SNMP, and DHCP.

**Advantage:** Finds UDP services that TCP scans miss.

**Limitation:** It is generally slower and results can be difficult to determine because many UDP services do not respond to unexpected packets.

## 3. SYN (Stealth) Scan

A SYN scan sends a TCP SYN packet and examines the response without completing the entire TCP handshake.

### Example:

```
sudo nmap -sS <TARGET_IP>
```

It is commonly used for efficient TCP port discovery.

**Advantage:** Fast and efficient, with less connection overhead than a TCP Connect scan.

**Limitation:** Firewalls and IDS/IPS systems can still detect or block SYN scanning.

## Conclusion

SYN scanning is generally effective for fast TCP port discovery, TCP Connect scanning is useful when a reliable full connection test is needed, and UDP scanning is essential when investigating UDP-based services.

**5) Suppose you are conducting an authorized security assessment and discover critical services (such as SSH, FTP, and database ports) exposed to the internet. How would you assess the risks and recommend mitigation strategies?**

If an authorized security assessment discovers critical services such as SSH, FTP, and database ports exposed to the Internet, I would assess the risks based on service type, exposure, vulnerabilities, authentication, and potential business impact.

### **1. Risk Assessment**

- **SSH:** Check whether the SSH version has known vulnerabilities and whether strong authentication is enabled. Password-based login and direct administrator/root access increase the risk of unauthorized access.
- **FTP:** FTP can expose credentials and data if encryption is not used. Anonymous access or weak authentication can further increase the risk.
- **Database ports:** Internet-facing database services are high-risk because attackers may attempt credential attacks, exploit software vulnerabilities, or gain unauthorized access to sensitive data.
- **Software versions:** Identify the versions of the exposed services and check them against known CVEs and security advisories.
- **Access requirements:** Determine whether each service actually needs to be publicly accessible. Unnecessary Internet exposure should be considered a high-priority issue.

### **2. Prioritization**

I would prioritize the risks based on:

1. Severity of the vulnerability
2. Ease of exploitation
3. Sensitivity of the data
4. Internet exposure
5. Potential business impact

## 6. Availability of security patches

For example, an Internet-facing database with a known critical vulnerability would normally receive higher priority than a properly configured SSH service.

### 3. Recommended Mitigation

#### SSH:

- Restrict SSH access to trusted IP addresses or through a VPN.
- Use strong authentication, preferably SSH keys and MFA where supported.
- Disable direct root login.
- Disable weak or unnecessary authentication methods.
- Keep the SSH server updated.

#### FTP:

- Disable FTP if it is not required.
- Replace traditional FTP with SFTP or FTPS where file transfer is necessary.
- Disable anonymous access.
- Use strong authentication and appropriate file permissions.

#### Database:

- Do not expose database ports directly to the Internet unless absolutely necessary.
- Place databases behind a firewall or private network.
- Allow access only from authorized application servers.
- Use strong credentials and least-privilege database accounts.
- Apply security patches regularly.
- Enable encryption and monitoring.



#### **4. Verification**

After implementing the mitigations, I would perform another authorized scan and configuration review to verify that unnecessary ports are closed, restricted services are no longer publicly accessible, and the identified vulnerabilities have been addressed.

#### **Conclusion**

Internet-exposed SSH, FTP, and database services increase the attack surface of an organization. The recommended approach is to remove unnecessary exposure, restrict required services, strengthen authentication, patch vulnerable software, and continuously monitor the environment. Critical vulnerabilities affecting Internet-facing services should be addressed first.